STAJ PROJESİ · TÜRKSAT AVIATION AND COMMUNICATION

Akıllı Okul Bilgi Sistemi

Hafta 3 — Kural Motoru (Rol Bazlı Erişim Kontrolü)

HAZIRLAYAN	Bera Ergin — s29315
KURUM	PJAIT — 7. Yarıyıl
BU HAFTA	Kimin neyi görebileceğini belirleyen kural motoru

Nereden Geliyoruz, Nereye Gidiyoruz

HAFTA 2 — BİTTİ

- ✓ FastAPI + JWT auth çalışıyor
- ✓ 4 rol doğru şekilde login oluyor
- ✓ Token içinde role/related_id var
- ✓ Ama hiçbir endpoint veri döndürmüyor

Token kimliği kanıtlıyor ama henüz hiçbir şeyi sınırlamıyor.

HAFTA 3 — HEDEF

- RuleEngine sınıfı — role göre filtre üretme
- Öğretmen → kendi sınıfı, veli → kendi çocuğu
- Bound parameter (SQL injection'a karşı)
- İzole birim + entegrasyon testleri

Henüz hiçbir API endpoint'ine bağlanmıyor — kural motoru kendi başına test ediliyor.

RuleEngine Tasarımı

Her rol için bağımsız bir filtre kuralı — dört satırlık mantık, ama tüm güvenliğin temeli

Müdür	principal	Filtre yok — tüm kayıtlar	`1=1`
Öğretmen	teacher	Yalnızca kendi sınıfı	`class_name = :class_name`
Veli	parent	Yalnızca kendi çocuğu	`id = :student_id`
Öğrenci	student	Yalnızca kendisi	`id = :student_id`

Not: Veli ve öğrenci filtreleri aynı görünüyor çünkü bir veli hesabının related_id alanı zaten çocuğun öğrenci id'sini tutuyor.

Neden Bound Parameter

String birleştirme yerine parametre bağlama — SQL injection'ı mimari seviyede imkansız kılmak

TEHLİKELİ — string birleştirme

```
f"SELECT * FROM students
WHERE class_name = '{related_class}'"
```

Eğer related_class = "9-A' OR '1'='1" gelirse, filtre tamamen devre dışı kalır.

GÜVENLİ — bound parameter

```
"SELECT * FROM students
WHERE class_name = :class_name"
params = {"class_name": related_class}
```

related_class artık bir SQL parçası değil, salt veri. Veritabanı sürücüsü değeri hiçbir zaman sorgu metnine karıştırmaz.

RuleEngine, hiçbir koşulda f-string veya % ile SQL üretmez — her değer SQLAlchemy'nin text()/bindparam() mekanizmasından geçer.

Test Stratejisi

İki katman: kuralın kendisi ve gerçek veritabanı üzerinde davranışı

Birim testleri

- Her rol doğru WHERE ifadesini üretiyor mu?
- related_class/related_id eksikse ValueError fırlıyor mu?
- Bilinmeyen rol (ör. 'hacker') reddediliyor mu?
- Üretilen cümlede hiç ham değer yok, sadece :param var mı?

Entegrasyon testleri

- Gerçek SQLite verisinde teacher1 sadece 9-A'yı görüyor mu?
- parent1 yalnızca kendi çocuğunu görüyor mu?
- principal tüm 12 öğrenciyi görüyor mu?
- SQL injection denemesi (') veri olarak mı işleniyor?

Örnek Test Çıktısı

```
pytest backend/tests/test_rule_engine.py -v
```

```
test_principal_sees_all                          PASSED
test_teacher_filters_by_class                    PASSED
test_parent_filters_by_child                     PASSED
test_student_filters_by_self                     PASSED
test_teacher_without_class_raises                PASSED
test_unknown_role_raises                         PASSED
test_integration_teacher_sees_only_9A            PASSED
test_integration_parent_sees_only_child          PASSED
test_sql_injection_attempt_is_literal            PASSED

9 passed in 0.14s
```

Bu Hafta Eklenen Bağımlılıklar

requirements-dev.txt — yalnızca test için, prod'a gerekmiyor

`pytest`	Test çalıştırıcı
`pytest-cov`	Kapsama (coverage) raporu

Hafta 2'den taşınanlar: fastapi, uvicorn, python-jose, passlib (değişmedi)

Hafta 3 — Kapsam ve Kabul Kriterleri

Bu hafta teslim edilenler

- ✓ backend/app/services/rule_engine.py — RuleEngine sınıfı
- ✓ 4 rol için bound-parameter SQL filtresi
- ✓ backend/tests/test_rule_engine.py — birim testleri
- ✓ Entegrasyon testleri (gerçek SQLite verisinde)
- ✓ SQL injection denemesini kapsayan bir test
- ✓ requirements-dev.txt (pytest, pytest-cov)

Kabul kriterleri

1. pytest backend/tests/ tüm testler PASSED döner
2. Teacher filtresi yalnızca kendi related_class'ını içerir
3. Parent/Student filtresi yalnızca kendi related_id'sini içerir
4. Üretilen SQL'de hiç ham string interpolasyonu yoktur
5. RuleEngine henüz hiçbir FastAPI route'una bağlı değildir

Sonraki Adım — Hafta 4

Doğal Dil → SQL (Claude ile LLM Entegrasyonu)

- POST /query uç noktası — ilk gerçek veri döndüren endpoint
- Claude ile doğal dil sorusunun SQL'e çevrilmesi
- Üretilen SQL'in RuleEngine'den geçirilmesi
- Yalnızca SELECT'e izin veren güvenlik kontrolü

Teşekkürler